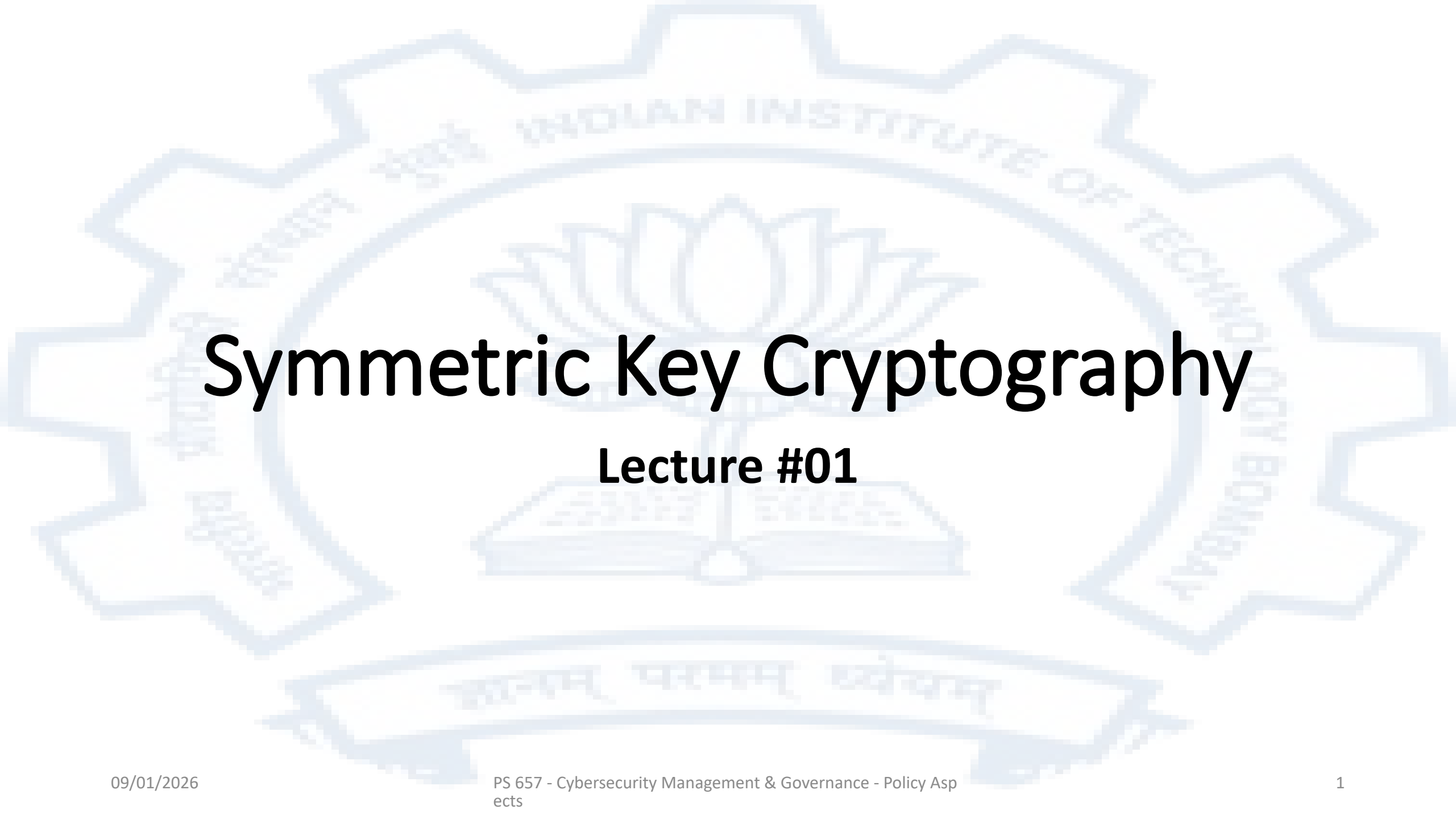


The background of the slide features a large, light blue watermark of the Indian Institute of Technology Bombay logo. The logo is circular with a gear-like outer border. Inside the circle, there is a lotus flower in the center, and the text "INDIAN INSTITUTE OF TECHNOLOGY BOMBAY" is written in a circular path around the lotus. At the bottom of the logo, there is a banner with text in Devanagari script.

Symmetric Key Cryptography

Lecture #01

Definition and Origins

Cryptography refers to a broad set of mathematical techniques that are used to transform data into a form that only someone with a certain knowledge is able to interpret. This knowledge is usually referred to as a “key”. Thus, once data is “encrypted” using some method, it can only be “decrypted” if one has knowledge of the “key”.

Cryptography has a long history

- There is evidence of the use of some type of cryptography in ancient Egypt in 1900BC
- There is evidence of clay tablets being written in a special way to protect information in Mesopotamia around 1500BC
- In India around 500BC the Kama Sutra describes the art of “mlechita vikalpa” which is a way for lovers to communicate
- The ancient Greeks knew of and used some simple cryptographic techniques
- Julius Caesar used a cryptographic technique in his writing. This is called the Caesar Cipher

The Caesar Cipher

The encryption part is to replace each letter in a message by the third letter that comes after it.

Decryption is done by reversing the process

A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z
D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C

Example:

MOUNT EVEREST IS THE HIGHEST PEAK IN THE WORLD (Plain text)

Becomes

PRXQW HYHUHVW LV WKH KLJKHVW SHDN LQ WKH ZRUOG (Cipher text)

This is a special case of a more general scheme where a letter is replaced by the n th letter that comes after it.

The Caesar Cipher is ROT3 but we could have ROT n

An even more general scheme can be to replace a letter by some other letter with the constraint that each letter corresponds to some other unique letter. These types of schemes are called substitution ciphers

Cryptanalysis – breaking monoalphabetic substitution ciphers

- The Arabs were the first people to document cryptanalytic techniques
 - Al-Kindi - *Risalah fi Istikhraj al-Mu'amma* (Manuscript for the Deciphering Cryptographic Messages)
- The frequencies of various letters and polygraphs in a language give the analyst information on what possible substitutions could be. For example, in English the most frequently occurring letter is E. Analysing the ciphertext will allow an analyst to guess which letter in the ciphertext could possibly be E and then to work out what n is if a ROTn cipher was being used
- Classical encryption systems are very vulnerable to frequency analysis

A more sophisticated scheme – The Vigenere Cipher

- In this scheme the letter at every is transformed using a different rotation
- The specific rotation is determined by a key. The key is repeated till it becomes equal to the message size
- Example

Message is : **ANIMAL** (6 letters)

Key is **CAT**

Extended key is **CATCAT** (6 letters)

A is encoded using the 3rd row (C)

N is encoded using the 1st row (A)

I is encoded using the 20th row (T)

M is encoded using the 3rd row (C)

A is encoded using the 1st row (A)

L is encoded using the 20th row (T)

The encrypted message is **YNPKAS**

A	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z
B	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y
C	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X
D	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W
E	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V
F	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U
G	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T
H	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S
I	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R
J	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q
K	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P
L	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O
M	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N
N	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M
O	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L
P	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K
Q	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J
R	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I
S	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H
T	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G
U	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F
V	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E
W	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D
X	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C
Y	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B
Z	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A

Shannon's concept of perfect secrecy

Shanon's Theorem:

Let (Gen, Enc, Dec) be an encryption scheme over a message space M for which $|M| = |K| = |C|$, the scheme is perfectly secret if and only if:

- 1) Every key $k \in K$ is chosen with equal probability of $1/|K|$*
- 2) For every $m \in M$ and every $c \in C$, there exists a unique key $k \in |K|$ such that encrypting m with k produces c*

The One Time Pad

- The One Time Pad scheme is a Vignere Cipher with a random key that is the same length as the message to be encoded. Moreover each key must only be used once.
- Advantages
 - The main advantage is that such a scheme is perfectly secret in the Shannon sense
- Disadvantages
 - Since messages may be long, it may be necessary to generate long random keys
 - These keys must be communicated securely
 - It is hard to ensure that a key is only used once

The impact of digital computers

- Before the advent of digital computers
 - The classical cryptographic techniques are only suitable for relatively small text messages
 - There was no easy way to encrypt non-text data such as images or maps
 - Encryption algorithms had to be simple enough to execute by hand
- After digital computers were in common use
 - All data is finally stored as strings of bits so all types of data can be encrypted
 - The computational power of digital computers allows very complex algorithms to be used
 - The computational power of computers can also be used to break encryption so much more emphasis is now placed on ensuring that encryption algorithms are resistant to cyptanalysis

Computational Security

In practical situations it may not be possible to have keys as long as the data to be encrypted. Therefore if the key-space is not very big an adversary may simply try all keys. Even if the key-space is large the algorithm used may permit shortcuts to significantly prune the keyspace.

An encryption scheme can be said to be computationally secure if there is no method that can decrypt a ciphertext in “reasonable” time. This means

1. The key-space should be big enough to make exhaustive enumeration attacks impractical
2. The algorithm should be such that an adversary is not able to do significantly better than an exhaustive enumeration attack

Symmetric Key Cryptographic Primitives

The three main symmetric key cryptographic primitives are

1. Block ciphers
2. Stream ciphers
3. Hash functions

Block Ciphers

A block cipher is a function

$$f: K \times \{0,1\}^b \rightarrow \{0,1\}^b$$

K is the key-space

b is the blocksize

A block cipher of size b can be thought of as a function that produces a permutation of a bitstring of size b given a key from a given keyspace

Stream Ciphers

A stream cipher is a scheme where a plaintext bitstream is combined with a continuous keystream to produce a continuous cipher stream where the ciphertext bit being produced depends upon the plaintext bit and the corresponding keystream bit.

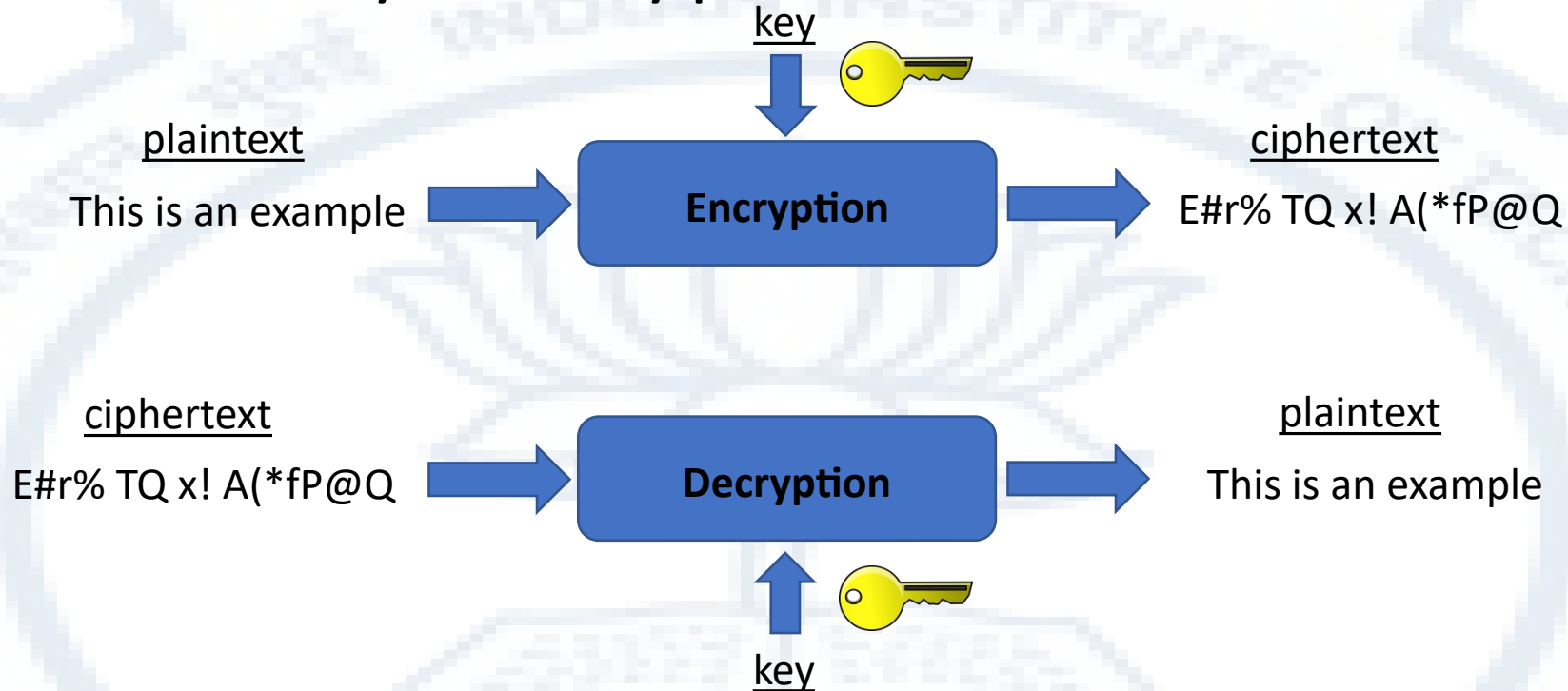
Theoretically the keystream should be random and unbounded but in practice some long base keystream is repeated periodically.

Hash Functions

A hash function takes in an unbounded input bitstream and produces a fixed size output. In general a hash function should use a key but in many cases a given hash function can be thought to have a specific inbuilt key.

In the case of hash functions it should not be easily possible to construct a bitstream whose hash value is equal to (collides) with the hash value of a given bitstream.

Symmetric Key Encryption



- The key used for encryption is the same as the key used for decryption and hence the term “symmetric” key encryption.
- The size of the ciphertext corresponding to a given plaintext is about the same as the size of the plaintext.
- A good “cipher” or encryption algorithm is one where security lies only in knowledge of the key. Knowledge of the algorithm should confer no advantage in decryption. Under this assumption the only way to decrypt without a key is to try all possible keys.

Breaking Encryption

- Modern ciphers are designed to ensure that knowledge of the algorithm will not provide any advantage if the keys are kept secret.
- This means the key lengths have to be chosen so that brute force attacks (trying all possible keys) are not computationally practical
- The standard encryption algorithm in use today is AES-256. Each key is 256 bits. The number of possible keys is therefore 2^{256} . If you were able to try a billion (10^9) keys a second it would still take of the order of 10^{58} billion years to try all keys.

What does breaking encryption mean?

- Exploiting a design weakness of the algorithm to significantly narrow the key search space.
- Exploiting an implementation weakness to get access to the key or the unencrypted stream
- Storing a copy of the key to be used to decrypt with lawful authority (key escrow)

Exploiting Design Weaknesses of the cryptographic algorithms- Cryptanalysis

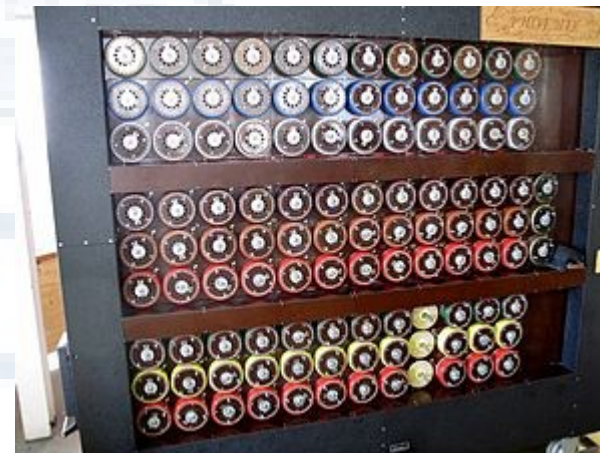
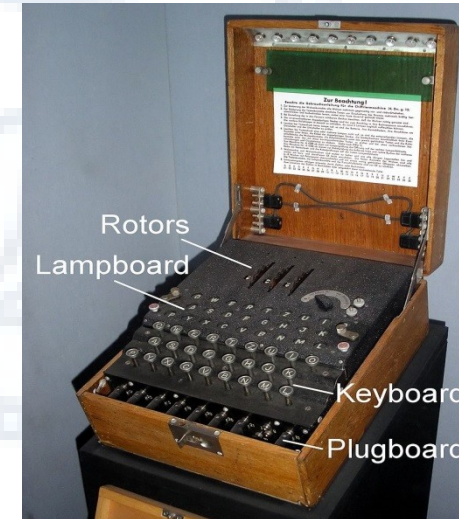
- Keeping an algorithm secret is not viable in the long run. There is a long list of examples of secret algorithms being revealed through various methods such as espionage, betrayal, reverse engineering or pure mathematical deduction
- Therefore it is prudent to assume “Shannon’s maxim” – ***The adversary knows the system***

Methods of Cryptanalysis

- Some methods are
 - Ciphertext only
 - Known plaintext
 - Chosen plaintext
 - Adaptive chosen plaintext
 - Chosen ciphertext
 - Adaptive chosen ciphertext
 - Related key
 - Linear cryptanalysis
 - Differential cryptanalysis
- Methods for breaking modern cryptosystems often involve solving carefully constructed problems in pure mathematics, the best-known being integer factorization.

Breaking the Enigma Cipher

- Enigma was a German “stream cipher” based machine
- Enigma was an electromechanical device and its sophistication was limited by that. Having said that it was still very good at its function
- Was used extensively by many branches of the German Government and Military. Each with its own variation
- Brought focus on security of cipher design
- The then new digital computer technology was seen as providing the required speed and reliability for more modern cryptographic algorithms that would be much harder to break



DES – The Data Encryption Standard

- Developed by IBM in 1970 based on earlier work by Fiestel
- Was a block cipher with a 56 bit key
- Was submitted to the US National Bureau of Standards (NBS)
- The NBS after consultation with NSA published a slightly modified version of the original algorithm as a standard – DES
- This led to suspicion and speculation that the NSA had deliberately weakened the cipher or put in a back door
- It has subsequently been revealed that
 - NSA strengthened it against a form of cryptanalysis that was known to them but unknown to the rest of the world. So it appears they removed a potential backdoor
 - However they weakened the cipher against brute force attacks by shortening the effective key from 64 bits to 56 so that with their superior computing power they could break it but brute force attacks would be impractical by others especially given the applications it was intended for
- Published in 1977 as a Federal Information Processing Standard FIPS PUB 46
- By the mid 1990s there was general agreement that the keysize of DES was too small and DES was extended to triple DES while the process of developing a new encryption standard – AES – was begun

AES – The Advanced Encryption Standard – Development Process

- The involvement of NSA and the controversy surrounding that in the design of DES resulted in NIST following a fully public process for the design of AES
- On January 2, 1997, NIST announced that they wished to choose a successor to DES to be known as AES. Like DES, this was to be "an unclassified, publicly disclosed encryption algorithm". However, rather than simply publishing a successor, NIST asked for input from interested parties on how the successor should be chosen.
- The result of this feedback was a call for new algorithms on September 12, 1997. The algorithms were all to be block ciphers, supporting a block size of 128 bits and key sizes of 128, 192, and 256 bits.

AES – The Advanced Encryption Standard – Development Process

- Fifteen designs were created and submitted from several countries. They were, in alphabetical order: CAST-256, CRYPTON, DEAL, DFC, E2, FROG, HPC, LOKI97, MAGENTA, MARS, RC6, Rijndael, SAFER+, Serpent, and Twofish.
- NIST held two conferences to discuss the submissions (AES1, August 1998 and AES2, March 1999), and in August 1999 they announced that they were narrowing the field from fifteen to five based on voting at the second conference
 - Rijndael: 86 positive, 10 negative
 - Serpent: 59 positive, 7 negative
 - Twofish : 31 positive, 21 negative
 - RC6: 23 positive, 37 negative
 - MARS: 13 positive, 84 negative
- On October 2, 2000, NIST announced that Rijndael had been selected as the proposed AES
- NIST won praises from the cryptographic community for the openness and care with which they ran the standards process. Bruce Schneier, one of the authors of the losing Twofish algorithm, wrote after the competition was over that "I have nothing but good things to say about NIST and the AES process."

AES – The Advanced Encryption Standard – Current Status

- AES is a symmetric key cipher that supports key sizes of 128, 192 and 256 bits. The 128 bit version is not recommended today
- The cipher operates in one of the following modes
 - Electronic Code Book (ECB) mode
 - Cipher Block Chaining (CBC) mode
 - Cipher Feedback (CFB) mode
 - Output Feedback (OFB) mode
 - Counter (CTR) mode
- Some theoretical attacks against AES have been published but it is still thought to be sufficiently secure for quite a while into the future

Vulnerabilities and Weaknesses in implementing cryptographic systems

- Even if an algorithm is theoretically strong, the following issues need to be addressed
 - Where are the keys stored?
 - How are the keys shared?
 - How are the keys protected when they are stored?
 - How are the keys protected when they are being shared with other parties?
- Are there vulnerabilities that will allow unauthorised users to use functionality that they are not supposed to or turn off security checks or access data stored in locations that are assumed to be secure due to assumptions about operating system security.

Protecting Keys

- All keys must be protected.
- The quality of key protection must be at least as good as the quality of protection provided by the key
- Therefore a each key is protected by some key encryption key
- While this hierarchy can be as deep as required, finally there must be a set of keys that are the primary roots of trust. How are these keys to be protected?
 - Encrypted by a key that is not stored on that system (i.e. a key derived from an entered password)
 - Stored in specialized hardware devices and activated by some means (usually a 4 to 6 digit PIN)

How good are Key Protection Techniques?

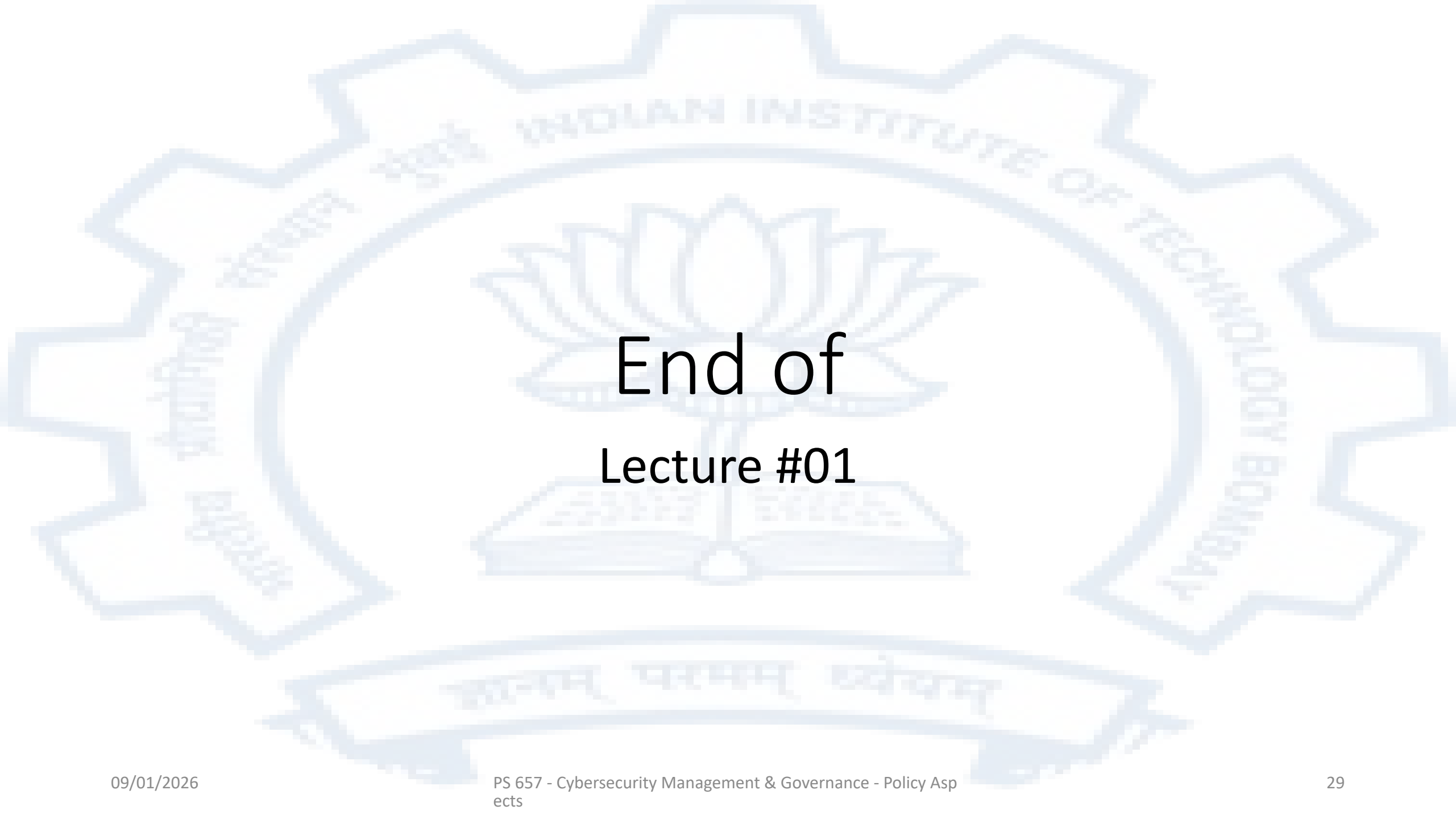
- A key size of 256 bits is considered as mandatory for sensitive transactions today
- Assuming that a password and a symmetric algorithm is used for key protection how many characters long would a password have to be? Assuming a character set of about 128 characters (a-z, A-Z, 0-9, special characters) which could be coded in 7 bits, the password would have to be 37 characters long which is far too long to be practical
- Storing keys in a hardware device may offer good protection against the key itself being extracted but with a 4-6 character PIN, without additional physical protection, key erasure after a number of wrong attempts is needed for adequate security.

Key Management

- A significant issue with symmetric key systems is how do two communicating parties share a key
- The problem with symmetric key systems is that each pair of participants need a distinct key. Therefore if there are n participants, nC_2 distinct keys are needed
 - For 1000 participants this will mean $(1000 \times (1000-1))/2 = 4,99,500$ keys
- Keys must be protected
- Keys must be rotated

To summarize

- Cryptography is a mathematical technique that can be used to convert data into a form in such a way that the original form can only be recovered by someone with knowledge of a “key”.
- Such techniques need to be carefully designed so that someone without the knowledge of the key cannot convert the data into its original form, either by examination and analysis of the method or by trying all possible keys.
- Techniques where encryption and decryption are done using the same key are called symmetric key encryption systems.
- For a symmetric key encryption system, both participants must find a way to share the key without any other person knowing the key. This is a significant problem.
- For a n participant symmetric key encryption system nC_2 distinct keys are needed. This is also a significant problem.

The background of the slide features a large, light blue watermark of the Indian Institute of Technology Bombay (IIT Bombay) logo. The logo is circular with a gear-like outer border. Inside the circle, there is a lotus flower in the center, and a banner at the bottom with the Sanskrit motto 'सत्यम् धर्मम् विद्यया' (Satyam Dharmam Vidhyaya). The text 'INDIAN INSTITUTE OF TECHNOLOGY BOMBAY' is written along the inner circle.

End of Lecture #01